Секреты

Инцидент: ключ GigaChat был закоммичен

Что произошло. Файл `.env` находился под контролем версий, хотя `.gitignore` содержал явное «Секреты — НИКОГДА не коммитить». В нём был рабочий `GIGACHAT_CREDENTIALS` (base64-ключ формата `client_id:client_secret`), а также `SECRET_KEY`, `ADMIN_SECRET_KEY` и `CHEAT_TESTER_CODE`. Файл менялся в 8 коммитах истории.

Что сделано. 1. `.env` удалён из индекса (`git rm --cached .env`) — новые коммиты его не содержат. 2. Добавлено сканирование секретов в CI (`.github/workflows/ci.yml`, job `secrets`, `gitleaks` с конфигурацией `.gitleaks.toml`). 3. `scripts/doctor.sh` проверяет, что `.env` не отслеживается git. 4. Инструкция «не коммитить» заменена проверкой, которая падает на pull request.

Что обязан сделать владелец проекта. Удаление файла **не отзывает ключ**: он остаётся в истории git и мог быть скопирован.

1. Перевыпустить `GIGACHAT_CREDENTIALS` в личном кабинете GigaChat Studio.
2. Сменить `SECRET_KEY` (подпись сессий), `ADMIN_SECRET_KEY`, `CHEAT_TESTER_CODE`.
3. Проверить журналы GigaChat на обращения с этого ключа.
4. Решить судьбу истории: очистка (`git filter-repo`) переписывает коммиты и требует согласованных действий всех, у кого есть клон. Приемлемый минимум — считать ключ скомпрометированным и ротировать его.

История очищена (2026-10-29, по решению владельца). Выполнено `git filter-repo`: путь `.env` удалён из всех 99 коммитов, все ссылки (ветки) переписаны, изменения отправлены force-push. Проверка на свежем клоне: `gitleaks git` — 0 находок.

Важные оговорки, которые остаются после очистки:

1. **Ключ всё равно надо перевыпустить.** Он был публично доступен; очистка истории убирает его из репозитория, но не отменяет утечку.
2. **Ссылки pull request'ов GitHub переписать нельзя.** PR #1 уже смержен, а `refs/pull/1/head` указывает на коммит из старой истории и обновлению не подлежит (`deny updating a hidden ref`). Объекты из этой ссылки остаются доступными по SHA, пока GitHub их не соберёт мусорщиком. Чтобы удалить их окончательно, нужен запрос в GitHub Support («removing sensitive data») — это действие владельца организации, из репозитория оно не выполняется.
3. Любой, у кого был клон до перезаписи, должен удалить его и клонировать заново: старый объект `.env` лежит и в его локальной папке.

Правила для этого проекта

Секрет	Где живёт	Последствие утечки
`SECRET_KEY`	`.env` / окружение	подделка сессии
`ADMIN_SECRET_KEY`	`.env` / окружение	доступ к админ-функциям
`CHEAT_TESTER_CODE`	`.env` / окружение	обход игровых правил
`GIGACHAT_CREDENTIALS`	`.env` / окружение	расход квоты GigaChat

1. Секреты задаются только через окружение. В репозитории — только `.env.example` с заглушками.
2. Отсутствие секрета выключает функцию, а не создаёт небезопасный режим: без `GIGACHAT_CREDENTIALS` AI-функции недоступны, игра работает.
3. Compose требует обязательные секреты (`${VAR:?…}`) и падает без них — это защита, а не неудобство.
4. Секреты не пишутся в логи: `app/logging_setup.py`, тесты `tests/test_security.py`.